Política de Seguridad de la Información

ISO/IEC 27001:2022 — Cláusula 5 (Liderazgo)

Código de documento	SGSI-DOC-003	**Versión**	1.5
Estado	Borrador	**Clasificación**	Interna
Propietario	Administrador único — Atalaya GP SL	**Autor**	El consultor (externo)
Fecha de emisión	08/05/2026	**Fecha de aprobación**	Pendiente
Aprobado por	Pendiente conforme a DOC-002 §4	**Registro de aprobación**	Sin acta de aprobación de esta revisión. No acredita implantación ni firma contractual.

Historial de versiones

Versión	Fecha	Autor	Descripción del cambio
0.1	08/05/2026	El consultor	Emisión inicial para revisión de la Dirección General y la propiedad
1.0	15/05/2026	Administrador único	Firma de la declaración y aprobación; sesión constitutiva del Comité
1.0	05/06/2026	Comité de Seguridad Convergente	Aprobación del desarrollo (§§4-9) por delegación expresa (SGSI-DOC-002 §4).
1.1	24/07/2026	El consultor	Alta de §6.4 (toma de conciencia) y §6.5 (recursos); no afecta a la declaración firmada (§3). Ver decisiones.md §16 y §21.
1.1	24/07/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.1 del desarrollo.
1.2	20/08/2026	El consultor	Recorte del historial de versiones a una línea por entrada, con referencia a decisiones.md donde procede. Sin cambios de fondo.
1.2	20/08/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.2.
1.3	20/08/2026	El consultor	Alta del rol Responsable del Tratamiento (RGPD) en la tabla de roles y responsabilidades (§6.1), diferenciado del Responsable del SGSI; referencia a SGSI-REG-008, SGSI-DOC-011 y SGSI-DOC-012.
1.3	20/08/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.3.
1.4	20/09/2026	Autor del caso	Revisión de coherencia de septiembre. Deltas y verificación en docs/fase1-iso27001/correcciones_2026-09.md. Sin cambios en la fecha de corte.
1.5	27/09/2026	Autor del caso	Revisión por dominios aplicables y alcance de controles. Corte 24/07/2026 conservado. Aprobación pendiente. Deltas: revisión 2026-09-27.

1. Objeto

Este documento establece la política de seguridad de la información de Atalaya Gestión Patrimonial SL, los principios que la desarrollan, el marco para los objetivos de seguridad de la información y la asignación de roles, responsabilidades y autoridades, en cumplimiento de la cláusula 5 de ISO/IEC 27001:2022.

La política se estructura en dos niveles deliberadamente: una declaración de compromiso de la propiedad (sección 3), de una página y en lenguaje llano, firmada por el administrador único; y el desarrollo de la política (secciones 4 a 9), aprobado por el Comité de Seguridad Convergente por delegación expresa. La razón es operativa y honesta: el compromiso de la propiedad solo es real si el firmante entiende lo que firma. Una firma sobre un documento técnico no leído no es liderazgo; es un riesgo documentado.

2. Referencias

- ISO/IEC 27001:2022, cláusulas 5.1, 5.2 y 5.3.
- ISO/IEC 27003:2017, orientación sobre la cláusula 5.
- SGSI-DOC-001 Contexto de la Organización y Alcance del SGSI.

3. Declaración de compromiso de la propiedad

Texto íntegro de la declaración firmada por el administrador único de Atalaya Gestión Patrimonial SL:

«La información sobre mi familia, nuestro patrimonio y nuestra seguridad es lo que alguien necesitaría para hacernos daño. Protegerla no es papeleo: es protección, igual que la escolta o las cámaras. Por eso asumo y hago mías estas cinco reglas:

- *Quiero que Atalaya proteja nuestra información con un sistema serio, y pongo los recursos para ello.*
- *Las normas que salgan de este sistema van a misa, empezando por mí. Si yo me las salto, no puedo pedir a nadie que las cumpla.*
- *Delego la dirección del sistema en la Dirección General y en el Comité de Seguridad, y la representación de la familia en Elena Vidal. Lo que ellos decidan dentro de este marco cuenta con mi respaldo.*
- *Quien detecte un problema y lo comunique tendrá mi agradecimiento, no represalias. Prefiero una mala noticia a tiempo que una buena mentira.*
- *Espero que este sistema mejore cada año, y pediré cuentas de ello una vez al año como mínimo.»*

Firmado: Administrador único. La declaración original firmada se custodia como registro del SGSI.

Nota sobre la transcripción. La declaración se conserva como texto histórico del escenario ficticio; el nombre que contiene corresponde a la representante de la propiedad. Los miembros de la familia se identifican por su rol en la documentación formal, incluido el informe ejecutivo revisado. Esta transcripción no acredita una firma real ni aprobación de esta revisión.

4. Política de seguridad de la información

Atalaya Gestión Patrimonial SL protege la confidencialidad, integridad y disponibilidad de la información patrimonial, personal y de seguridad de la familia a la que sirve, dentro del alcance definido en SGSI-DOC-001, con el fin de proteger a las personas —tres de ellas menores—, el patrimonio y la reputación de la familia, y para ello se compromete a:

- Cumplir los requisitos legales, regulatorios y contractuales aplicables, incluidos los derivados del RGPD y de las obligaciones de confidencialidad frente a terceros.

- Gestionar la seguridad de la información y la seguridad física como un único sistema: todo control físico con componente de información (videovigilancia, control de accesos, domótica) y todo control lógico con efecto físico se planifican, operan y revisan de forma conjunta.
- Tratar los riesgos conforme a la metodología aprobada, priorizando la confidencialidad de rutinas, ubicaciones y dispositivos de protección de la familia.
- Establecer objetivos de seguridad de la información medibles conforme al marco de la sección 5, y mejorar continuamente el SGSI.
- Extender los requisitos de seguridad a todo tercero con acceso físico o lógico a la información en alcance, mediante acuerdos proporcionados a su acceso real, no a su vínculo formal.

El incumplimiento deliberado de esta política y de sus normas de desarrollo tiene consecuencias conforme a la sección 8.

5. Marco para los objetivos de seguridad de la información

Los objetivos de seguridad de la información (cláusula 6.2, documento SGSI-DOC-005) se establecen anualmente por el Comité de Seguridad Convergente y deben cumplir tres condiciones: derivar de los resultados de la evaluación de riesgos, ser medibles con los medios reales de una organización de nueve personas, y no degradar la operativa de la familia. Como orientación inicial, los objetivos del primer ciclo se centrarán en: control del acceso de terceros y del círculo de confianza, aseguramiento del canal con los asesores externos, verificación de órdenes financieras y reducción de la exposición de información de rutinas familiares.

6. Organización de la seguridad: roles, responsabilidades y autoridades

6.1 Estructura

La estructura de gobierno del SGSI reconoce una particularidad del contexto (SGSI-DOC-001, sección 5): la autoridad formal reside en el administrador único, pero la interlocución efectiva corresponde a su cónyuge y a la Dirección General. En lugar de ignorar esta dualidad, el SGSI la formaliza:

Rol	Responsabilidades y autoridad
Administrador único (el principal)	Aprueba la declaración de compromiso y la asignación de recursos. Delega formalmente la dirección del SGSI en el Comité de Seguridad Convergente. Recibe cuentas al menos una vez al año (revisión por la dirección).
Representante de la propiedad (cónyuge del principal)	Rol sin equivalente en la norma y justificado por el contexto, que no inventa una figura nueva sino que formaliza una que en estas casas ya existe de facto (ESC-001 §10): representa a la familia ante el SGSI y al SGSI ante la familia. Único canal autorizado para acordar con los miembros de la familia las normas que les afectan (exposición digital, dispositivos, invitados). Miembro del Comité con voto. Suscribe el acuerdo de confidencialidad SGSI-ACU-003: es la única persona con acceso pleno al sistema sin vínculo laboral, y esa obligación debe existir por escrito como la de cualquier otro.
Comité de Seguridad Convergente	Órgano de dirección del SGSI por delegación. Composición: Dirección General (preside), representante de la propiedad, jefe de seguridad y responsable financiero. El consultor externo asiste con voz y sin voto durante la implantación. Se reúne trimestralmente y de forma extraordinaria ante incidentes relevantes. Aprueba políticas de desarrollo y los objetivos anuales, y ratifica el riesgo residual de nivel Alto de los planes de tratamiento, cuya aprobación y cuya aceptación del residual corresponden al propietario de cada riesgo (ISO/IEC 27001 6.1.3 f; SGSI-DOC-004 §4.4).
Dirección General — Responsable del SGSI	Responsable designada de que el SGSI cumpla ISO/IEC 27001 y de informar de su desempeño a la propiedad (cláusula 5.3.a y 5.3.b). Propietaria del riesgo residual aceptado en el ámbito de gestión. Gestiona el presupuesto de seguridad.

Rol	Responsabilidades y autoridad
Responsable del Tratamiento (RGPD)	Atalaya Gestión Patrimonial SL, representada operativamente por la Dirección General. Rol RGPD, distinto del Responsable del SGSI de la fila anterior: aquel responde ante ISO/IEC 27001 por el sistema de gestión completo; este responde ante el RGPD por los tratamientos de datos personales identificados en SGSI-REG-008 (Registro de Actividades de Tratamiento). Los tratamientos, sus encargados y sus bases jurídicas se documentan en SGSI-REG-008, SGSI-DOC-011 (ponderación del interés legítimo) y SGSI-DOC-012 (EIPD).
Jefe de seguridad	Responsable de la convergencia: propietario de los controles físicos con componente de información (CCTV, accesos, domótica) y de su capa lógica, con autoridad para exigir al MSP el cumplimiento de los requisitos de seguridad sobre dichos sistemas. Integra los indicios físicos y digitales en la gestión de incidentes.
Responsable financiero	Propietario del procedimiento de verificación de órdenes e instrucciones financieras. Custodio del canal seguro con los asesores externos de España e Irlanda.
Asistente personal del principal	Rol crítico formalizado: custodia la identidad digital del principal (correo, credenciales, firmas). Obligaciones reforzadas de confidencialidad, doble verificación en actos de disposición y trazabilidad de los actos realizados en nombre del principal.
Todo el personal de Atalaya	Cumplir la política y sus normas de desarrollo, completar la formación asignada y comunicar incidentes y debilidades sin demora por el canal establecido.
Círculo de confianza y terceros con acceso	Sujetos a las obligaciones de seguridad establecidas en sus acuerdos específicos (personas del círculo histórico) o contratos (MSP, seguridad física, agencia de comunicación, personal doméstico). El nivel de exigencia se determina por el acceso real, no por la naturaleza del vínculo.

6.2 Segregación de funciones

Con una estructura de nueve personas —de las que siete son empleados y dos, escolta/conductor externos estables—, la segregación completa de funciones es materialmente imposible. La organización lo declara y lo compensa: las operaciones críticas (disposiciones patrimoniales, cambios en accesos físicos o lógicos, alta de terceros) exigen intervención de dos personas de roles distintos, y los actos realizados por delegación (en particular los de la asistente personal en nombre del principal) quedan registrados y son revisables por la Dirección General. La eficacia de estos controles compensatorios se evalúa en la auditoría interna.

6.3 Competencias y transferencia de conocimiento

Cada rol con responsabilidades en el SGSI tiene definidas competencias mínimas, registradas en una matriz simple que mantiene la Dirección General: al Comité se le exige comprensión de la metodología de riesgos y de los criterios de aceptación; al jefe de seguridad, capacidad de supervisión técnica de los sistemas convergentes (adquirida por formación específica si es preciso); al responsable financiero, dominio del procedimiento de verificación. Las carencias se cubren con formación planificada (objetivo O5), no se disimulan. La matriz de competencias y el registro de la formación impartida —quién, qué contenido, cuándo y con qué resultado— se conservan como información documentada del SGSI conforme a SGSI-DOC-002, porque la cláusula 7.2 no se satisface definiendo la competencia sino acreditándola.

El consultor externo tiene fecha de salida por diseño: su plan de transferencia incluye la documentación completa del sistema, sesiones de traspaso a la Dirección General y al jefe de seguridad durante el primer ciclo, y una cláusula de no dependencia: a partir del segundo ciclo, el SGSI debe poder operarse sin consultor, cuya intervención queda limitada al acompañamiento de la transferencia y de la revisión anual. La auditoría interna corresponde a una persona independiente del trabajo que audita, conforme a DOC-010 §2.1. Un sistema que muere cuando se va quien lo montó no es un sistema: es una consultoría permanente.

6.4 Toma de conciencia (cláusula 7.3)

Toda persona que trabaja bajo el control de la organización debe conocer la declaración de compromiso y la política, entender qué aporta su trabajo concreto a la eficacia del SGSI y saber qué implica no cumplirlo. El vehículo es el que ya establece la sección 7: la sesión única en la que el principal comunica en persona la declaración, y la formación por rol del objetivo O5, ambas con asistencia registrada. El universo alcanzado son las once personas con vínculo estable —los siete empleados, los dos escolta/conductor externos y las dos del círculo de confianza— y, con contenido proporcionado a su acceso y por vía contractual, el personal doméstico, el proveedor de servicios gestionados y la persona designada de la agencia de comunicación, que son terceros T1 y T2 con acceso diario a la casa o a los sistemas (SGSI-DOC-006 §2 y §3). Dejarlos fuera sería declarar consciente a quien redacta las normas e inconsciente a quien abre la puerta. Con la familia el requisito no se exige, se acuerda, porque el alcance la excluye expresamente como usuaria del sistema (SGSI-DOC-001 §7.3); lo que sí se exige es que la representante de la propiedad conozca el sistema que representa. La distinción entre exigir y acordar es la misma que recorre todo este SGSI, y aquí también se declara en lugar de disimularse.

6.5 Recursos (cláusula 7.1)

El Comité determina en cada ciclo los recursos necesarios para establecer, implementar, mantener y mejorar el SGSI, y los eleva al administrador único, que los aprueba en cumplimiento de la regla primera de su declaración. Los del primer ciclo constan en SGSI-DOC-005 §2 y son de tres clases: tiempo de personal reservado de forma explícita en la planificación trimestral, contratación externa —verificación técnica independiente, auditoría interna y asesoramiento legal— e inversión en los medios físicos y lógicos que exigen los objetivos O7 y O8. La adecuación de los recursos es entrada obligatoria de la revisión por la dirección (SGSI-DOC-010).

7. Comunicación y disponibilidad

Esta política se comunica a todo el personal en su incorporación y tras cada revisión, y se pone a disposición de las partes interesadas externas que la requieran en versión pública resumida, sin información confidencial. La declaración de la sección 3 se comunica además verbalmente por el propio principal al conjunto del personal y del círculo de confianza en una sesión única: en esta organización, ese acto vale más que cualquier circular.

Plan de comunicación del SGSI (cláusula 7.4) — qué, quién, a quién, cuándo y cómo:

Qué	Quién	Cuándo	Cómo / a quién
Política y normas de desarrollo	Dirección General	Incorporación y tras cada revisión	Sesión presencial + repositorio; al círculo, con presencia del principal
Objetivos del ciclo y su grado de cumplimiento	Dirección General	Al aprobarse y en cada revisión trimestral	Sesión con los responsables de cada objetivo + repositorio
Normas que afectan a la familia	Representante de la propiedad	Al acordarse y ante cambios	Conversación directa; nunca por circular
Estado del SGSI y riesgos	Dirección General	Trimestral (Comité) y anual (propiedad)	Sesión del Comité; informe ejecutivo SGSI-INF
Incidentes y avisos	Jefe de seguridad	Inmediato según severidad (DOC-009 §4)	Canal único; a la propiedad vía Dirección General
Requisitos a terceros	Dirección General	Alta, renovación y cambios	Contrato o acuerdo; confirmación escrita
Reglas de verificación a bancos	Responsable financiero	Al establecerse y ante cambios	Comunicación escrita registrada (DOC-007 R2)

8. Cumplimiento

Los incumplimientos de esta política se gestionan conforme al proceso disciplinario aplicable al personal, a las cláusulas de los contratos con terceros y a los acuerdos específicos con el círculo de confianza. La comunicación de buena fe de errores propios o incidentes no genera represalia, conforme a la declaración de la propiedad.

9. Revisión

El Comité de Seguridad Convergente revisa esta política al menos una vez al año y ante cambios significativos del contexto, de la estructura o del resultado de la evaluación de riesgos. Las modificaciones de la declaración de compromiso (sección 3) requieren nueva firma del administrador único.

Anexo A. Trazabilidad con ISO/IEC 27001:2022

Sección de este documento	Cláusula / control ISO/IEC 27001:2022
3 — Declaración de compromiso	5.1 Liderazgo y compromiso
4 — Política	5.2 Política
5 — Marco de objetivos	5.2.b (marco para objetivos; desarrollo en 6.2)
6 — Roles y responsabilidades	5.3 Roles, responsabilidades y autoridades; Anexo A 5.2, A 5.3, A 5.4
6.3 — Competencias y transferencia	7.2 (competencia)
6.4 — Toma de conciencia	7.3
6.5 — Recursos	7.1
7 — Comunicación	5.2.e, 5.2.f, 5.2.g; 7.4